

AI-POWERED COMPLIANCE SERVICES

AI 驱动合规， 帮助 出海企业 自信进入 全球市场

AIConform 将 AI 自动化能力、海外专业审计资源与数据隐私治理经验结合，为中国企业和全球化团队提供覆盖认证、数据保护、AI 治理与安全测试的端到端合规服务。我们尤其适合 AI+硬件设备、SaaS、App、平台型产品以及正在拓展欧美市场的企业。

SOC 2 / ISO 27001 / ISO 42001

GDPR / CCPA / HIPAA 隐私风险扫描

EU AI Act / NIST AI RMF

渗透测试 / 漏洞扫描

律师事务所联合服务

适配出海、融资、招投标与大客户准入

30-60%

审计周期缩短

25-50%

合规成本下降

15+

支持国际框架与法规

24/7

持续监控与风险发现

100%

审计材料可追溯

自动化

合规报告与证据生成

COMPANY OVERVIEW

不仅帮助企业通过审计，更帮助企业建立可持续的全球合规能力

AIConform 面向需要进入海外市场、服务大型客户或处理敏感数据的企业，提供从准备、差距分析、整改、取证到审计交付的完整服务。除认证项目外，我们还提供数据隐私扫描与整改建议，帮助企业识别 GDPR、CCPA/CPRA、HIPAA 等法规相关风险，并为出海场景建立更稳健的数据治理能力。

我们通过 AI 驱动的数据资产发现、风险优先级排序和自动化证据收集，缩短准备周期并减少手工复核。结合本地化项目管理与海外审计专家支持，帮助企业在多语言、多法域环境下更高效推进合规落地。

认证

SOC 2、ISO 27001、ISO 42001 等
端到端项目支持

隐私

识别 PII / PHI / 敏感数据与跨境数
据流风险

整改

提供制度、流程、配置与技术层面
的修复方案

我们为哪些企业创造价值

- 1 出海企业：**面向欧美客户销售 SaaS、App、智能设备或 AI 产品，需要满足企业采购、法律和安全审查要求。
- 2 AI + 硬件 / AI Agent 企业：**涉及模型治理、数据保护、访问控制、漏洞防护和法规风险控制。
- 3 融资与大客户准入场景：**需要更快拿到 SOC 2 / ISO 27001 等证明材料，增强客户信任和销售转化。
- 4 多法域数据处理场景：**需要系统盘点数据资产、识别跨境传输和敏感数据处理义务。
- 5 跨境数据共享场景：**需要统一管理海外数据流、委托处理与供应链合规风险。
- 6 合规运营与治理场景：**希望把合规工作嵌入产品、开发和运营节奏，形成长期可复用的治理体系。

AIConform 的差异化

- ✓ AI 自动化 + 人工专家双轮驱动，减少重复性取证、追踪和人工整理。
- ✓ 不仅做“合规咨询”，还提供落地整改支持，帮助客户把要求真正落实到流程和系统中。
- ✓ 支持认证、隐私、AI 治理、安全测试与律师协同，避免多供应商反复切换。
- ✓ 适合中国团队沟通和出海需求，理解出海企业在语言、流程和市场标准上的实际痛点。
- ✓ 基于风险优先级的审计计划，帮助企业聚焦最关键控制点。
- ✓ 提供中文项目经理与海外审计专家联动，降低跨文化沟通成本。

COMPLIANCE PLATFORM

统一的实时合规监控平台

把认证进度、风险等级、证据收集和整改状态统一到一个清晰的界面中，便于管理层、工程团队和审计方共享视图、快速协作。



DATA PRIVACY SERVICES

数据隐私扫描与整改支持

面向处理用户数据、健康数据或跨境数据的企业，AIConform 提供数据发现、隐私风险识别、法规映射和整改建议，帮助客户更系统地满足 GDPR、CCPA/CPRA、HIPAA 等要求。

我们做什么

把隐私合规从“只看法律条文”转向“数据、系统、流程和权限的真实治理”。

自动扫描并识别 PII、PHI、财务数据及其他敏感信息分布情况

梳理数据流、存储位置、访问路径与第三方处理方

映射 GDPR、CCPA/CPRA、HIPAA 等法规要求，识别高风险处理场景

输出整改建议：制度更新、权限治理、数据最小化、留存策略、访问审计与供应商管理

特别适合的业务场景

- A AI + 硬件设备：**设备端、云端和 App 端同时采集数据，涉及多端协同与敏感信息保护。
- B App / SaaS / 平台产品：**需要识别 cookies、账号、日志、地理位置、营销数据和跨境流动风险。
- C 医疗与健康科技：**关注 PHI、访问控制、留存策略、第三方处理和 HIPAA 相关义务。
- D 出海企业：**帮助企业更早识别合规短板，避免进入欧美市场后再被动补救。



敏感数据发现

发现个人信息、健康信息、支付数据、日志与元数据风险点。

PII

PHI

Data Discovery



数据流映射

梳理采集、传输、存储、共享与删除流程，形成更清晰的数据资产视图。

ROPA

Data Flow



法规映射

把技术事实映射到 GDPR、CCPA/CPRA、HIPAA 等义务条款，明确风险来源。

GDPR

CCPA

HIPAA



整改建议

给出可以执行的整改方案，包括权限、流程、政策、供应商和系统配置调整。

Remediation

Controls

WHAT WE OFFER

端到端合规与安全服务体系

我们既支持一次性认证项目，也支持持续合规运营；既覆盖安全与隐私框架，也覆盖 AI 治理与系统安全测试。



准备与差距分析

评估当前状态、控制缺口、政策缺失和取证难点，形成优先级清晰的整改路线图。

Gap Assessment

Roadmap



制度与控制设计

协助建立或优化政策、流程、权限管理、供应商管理、变更管理和审计机制。

Policies

Controls



证据收集自动化

通过集成平台自动拉取日志、权限、配置和操作记录，减少审计准备的人工工作量。

Evidence

Automation



审计协同与交付

协助客户完成审计准备、问题响应、材料补充和项目推进，直至审计报告出具。

SOC 2

ISO



系统安全测试

提供漏洞扫描、渗透测试、云配置审计、AI Agent / LLM 对抗安全测试等支持。

Pentest

Vuln Scan

AI Security



持续合规运营

适用于已拿到认证后仍需持续维护控制、更新证据、跟踪风险并应对客户问卷的企业。

Continuous Compliance

vCISO

AI 微代理能力示例

访问控制复核

自动识别离职员工、超权账户和长期未用权限。

供应商风险评估

跟踪第三方安全问题、合同与数据处理义务。

员工入职检查

核查账号、权限、培训与背景流程是否完成。

证据验证

自动核对日志、配置和文档版本是否满足控制要求。

SUPPORTED FRAMEWORKS

覆盖主流安全、隐私与 AI 治理框架

适合正在拓展海外市场、需要通过客户安全审查、融资尽调或建立成熟治理体系的技术公司。

AIConform 通过统一的控制框架与方法论，将安全、隐私与 AI 治理要求整合到企业的技术与运营体系中，减少多框架并行带来的复杂度，帮助企业在不同市场与监管环境下保持一致的合规与风险管理能力。

SECURITY**SOC 2**

适合 SaaS 与技术企业建立对外信任，支持企业销售与客户准入。

SECURITY**ISO 27001**

国际通行的信息安全管理体系，适合跨境和大客户场景。

AI GOVERNANCE**ISO 42001**

面向 AI 系统治理、生命周期管理与风险控制。

AI GOVERNANCE**EU AI Act**

适用于进入欧洲市场或涉及高风险 AI 应用的团队。

PRIVACY**GDPR**

适用于处理欧盟居民个人数据的组织和跨境业务。

PRIVACY**CCPA / CPRA**

适合美国消费者数据管理和隐私透明度要求场景。

PRIVACY**HIPAA**

面向健康科技、医疗数据和 PHI 管理相关业务。

RISK**NIST AI RMF / CSF**

帮助建立 AI 风险治理和更系统的网络安全管理方法。

典型客户画像

- 高成长 SaaS / App 企业，希望拿下美国或欧洲大客户。
- AI + 硬件 / 智能设备企业，需要管理设备、App 和云端的多端数据风险。
- 医疗科技 / 健康数据企业，需要同时考虑安全、隐私与审计要求。
- 正在融资、上市前准备或进入海外渠道的企业，需要更体系化的治理能力展示。

为什么特别适合出海企业

- 1 把技术、管理和法律要求翻译成企业可执行的整改动作。
- 2 帮助企业在欧美客户问卷、采购审查和安全审查中更从容地展示能力。
- 3 更早发现数据隐私风险，减少进入目标市场后被动修补的成本。
- 4 支持多框架协同，避免各部门分头应付不同标准造成重复投入。

HOW WE WORK

高协作、低摩擦的交付方式

我们通过统一平台、固定项目节奏和专家协同机制，让客户团队能在不影响业务推进的前提下完成合规项目。



联合项目管理

业务、技术、法务与外部审计在统一节奏下协同推进。



清晰责任分工

每个控制项、证据项和整改动作都有责任人与状态跟踪。



自动化优先

优先通过系统集成和AI自动化降低重复劳动和项目拖延。



对外可展示

帮助客户把治理能力转化为更可被客户理解和认可的信任资产。

对客户直接商业价值

- ✓ **更快成交**：缩短客户安全审查与供应商准入周期。
- ✓ **更低成本**：减少外部顾问、内部协调和重复取证的浪费。
- ✓ **更强信任**：让安全、隐私和AI治理成为商业加分项，而不是阻碍项。
- ✓ **更可持续**：建立持续监控和运维能力，而不是“一次性通过”。
- ✓ **更高转化**：提升海外客户、渠道与合作伙伴的信任转化率。
- ✓ **更低风险**：提前识别安全与隐私问题，减少合规事故与法律风险。

典型 ROI 指标

更稳

降低安全与隐私合规风险暴露

更高

提升客户信任与长期合作价值

30-60%

审计准备与项目周期缩短

25-50%

合规项目整体成本优化

持续

证据、风险和整改状态可追踪

更快

响应大客户、投资人和审计要求

DELIVERY PROCESS

五步交付流程：从评估到报告交付

从初始评估到整改、取证、审计协作和持续运营，AIConform 提供完整陪跑式支持，帮助客户形成长期可复用的治理体系。

01

Assess

梳理业务、系统、数据流和项目边界，明确目标框架与范围。

02

Identify

开展差距分析、风险识别和优先级排序，形成整改路线图。

03

Address

落实控制、政策、权限、日志与流程整改，并建立取证节奏。

04

Prepare

整合证据、补齐材料、演练审计问答，提升项目成熟度。

05

Report

协同完成审计流程，推动项目至审计报告出具，并支持后续持续运营。

让合规成为出海的竞争优势

无论您是正在准备 SOC 2 / ISO 27001，还是希望识别数据隐私风险、建立 AI 治理体系，AIConform 都可以帮助您用更专业、更高效的方式完成项目。

联系方式

hlu@aiconforms.com
www.aiconform.ai
San Jose, CA 95134, USA

[预约咨询](#)**我们还支持**

ISO 27701 · PCI DSS · DORA
· NIST CSF · AI 风险治理 ·
云安全配置审计 · 第三方安全
问卷支持 · 数据隐私扫描 · 跨境数据合规

适用企业

出海 SaaS / App 企业 · AI + 硬件设备公司 · 医疗健康科技企业 · 平台型数据业务 · 需要通过客户安全审查或融资尽调的技术团队